VODAFONE PROCUREMENT & CONNECTIVITY

Agent Marketplace

Guide to the governance pack: what each artefact is, who reads it, and what question it answers.

Submitted for	AI Portfolio Board, Security assessment, Privacy assessment, Vodafone Group review
Ask	Approval to deploy into Production
Pattern	Reusable AIB architecture on Google Cloud
Projects	vf-grp-aib-prd-mirror (web), vf-grp-aib-prd-scm-vpc-xx (backend), vf-grp-aib-prd-proxy (LLM, existing)
Classification	Confidential, CMEK, environments lab / non-live / live
Service owner	Procurement AI Operations
Document owner	Praveen Orvakanti, AI Domain, VP&C

The one-line argument

The marketplace is a catalogue and a front door, not a runtime. Agents keep running on their own platforms under their own approvals. No supplier record, contract, purchase order, invoice, price or spend figure is read, stored or transmitted on any path, and SAP, Ariba and Datasphere are not integrated with it. That exclusion is what makes the risk profile low, and it is an architectural property rather than a policy promise: there is no connection, credential or network path to those systems.

How to use this pack

The pack is one submission read by four different audiences. Nobody needs all of it. The table below is the reading order per audience; the sections after it describe each artefact in turn.

Audience	Read, in this order	Why
AI Portfolio Board	Board slides, then HLD sections 1 to 2 and 8	The ask, the scope and exclusions, and how AI is used
Security assessor	Diagram 02, then the security control matrix, then HLD section 5, then diagram 05	The deployment reality, what is inherited versus new, the threat model, and proof that the tier split is real
Privacy assessor	DPIA, then diagram 03, then the DDL	The personal data inventory, the boundary crossings, and retention declared in the schema
Architect or Group reviewer	HLD end to end, then diagrams 01, 02 and 04, then the API contract	The full design, its rationale, and the interface that makes the tier split enforceable

The review surface

Most of this stack is already approved. The orchestration boundary, Responsible AI screening, model serving and the identity chain are existing AIB components whose controls this use case inherits rather than rebuilds. What is new is the web tier, the backend service, the data model and the service perimeter around them. Diagram 02 colour-codes which is which, and the security control matrix sets it out control by control. A reviewer should spend their time on the blue components.

The artefacts

Twelve files. Six documents, five diagrams and one slide pair.

1	**`README.md`**	Index and submission checklist	All reviewers

The map of the pack. States the one-line argument, the reading order, the review-surface concept and the items that still need an owner. Hand this over first so nobody has to guess what exists.

2	**`HLD-agent-marketplace.md`**	The submission itself	All reviewers

Scope and explicit exclusions, the two-tier architecture, deployment decisions with their rationale, security and authorisation architecture, an abbreviated threat model, the data architecture, AI usage, a well-architected review across the five Google Cloud pillars, nine open items with named owners, and a table of what changed from the pilot. This is the document the Board approves.

3	**`DPIA-agent-marketplace.md`**	Data Protection Impact Assessment	Privacy

Standalone, because Privacy will want it separately from the architecture. Screening against the DPIA triggers, a twelve-row personal data inventory with purpose and necessity per element, the pseudonymisation design, the retention schedule, data subject rights including the audit exemption claimed, and an eight-row risk register with residual ratings.

4	**`security-control-matrix.md`**	Inherited versus implemented controls	Security

Around forty controls across identity, network, data, AI, software supply chain and operations. Each is tagged inherited from AIB, new for this use case, or shared, with the evidence a reviewer would ask to see. It ends with four declared gaps: a reviewer who finds an undeclared gap discounts everything else in the pack.

5	**`api-contract.md`**	Frontend to backend interface	Security, architects

Thirteen endpoints, the bearer-token call shape, and the five rules the backend enforces that the frontend cannot bypass. This exists because the two-tier split is the main security property of the design, and a reviewer needs to see that it is a real boundary with a real contract rather than a line on a picture.

6	**`schema/bigquery-ddl.sql`**	Executable BigQuery schema	Data governance, privacy

All eight data domains as runnable DDL, with purpose documented per column and retention set as partition_expiration_days per table. Retention therefore becomes platform behaviour rather than a scheduled job somebody has to maintain and evidence to an auditor.

Diagrams

All five are generated rather than hand-drawn, so they stay consistent when the architecture moves. They use the official Google Cloud product icon set and follow Google's diagramming conventions: containment carries the meaning, services are icons rather than boxes, and connectors are typed by colour with a legend. Each ships as an editable SVG and a 2x PNG.

7	**`01-logical-architecture`**	Capabilities and domain boundaries	Board, architects

The nine backend domain services with their responsibilities, the eight data domains, the model-usage scope, and the agent platforms the marketplace catalogues but does not operate. Read this before the deployment view.

8	**02-deployment-architecture**	What is actually deployed	Architects, security

The anchor diagram. Web layer and the existing AIB layer, real project names, the service perimeter, and an eight-step numbered request path along the bottom. Components are colour-coded by review surface.

9	**03-data-flow**	Trust boundaries and data classification	Security, privacy

Seven trust boundaries and ten numbered flows, each tabulated with what data travels, whether it is personal data, its purpose and its retention. Carries the exclusion statement and names where the residual privacy risk sits.

10	**04-catalogue-data-lifecycle**	How agent information lives and moves	Architects, data governance

The three write paths into the catalogue with the control on each, and the read path including the cache. Explains why votes are appended as events rather than updated in place, and records the alternative that was considered and rejected.

11	**05-sequence-flows**	Three request sequences, end to end	Security

Page load, casting a vote and Concierge search, across seven lifelines. The diagram a security reviewer should see first: it shows that the frontend lifeline and the BigQuery lifeline are never joined by an arrow in any flow, and that every operation crosses the gateway carrying the end user's own token.

12	**AI-Portfolio-Board-Agent-Marketplace.pptx**	Board pack entry	AI Portfolio Board

Two slides in the Why and How format the Board already uses, so it drops into the existing pack without looking foreign. Slide one carries the problem statement, benefit, data needs and the exclusion that bounds the assessment. Slide two carries the block architecture with the six points a reviewer needs beside it. Both have speaker notes.

What reviewers will ask, and where the answer is

Drawn from the questions the Emplay submissions attracted and from the design decisions most likely to be challenged.

Question	Answer	Where
Is this another platform to maintain?	No. A front door, not a runtime. Agents stay where they live.	HLD 1, 2.2
What personal data does it hold?	Vodafone employee work email, name, role and user-written free text. No customer or supplier personal data.	DPIA 4
How long is it kept?	90 days to seven years depending on the table, enforced as partition expiry in the DDL.	DPIA 6, DDL
Can the frontend reach the database?	No. It holds no credential and appears on no flow that reaches the data layer.	Diagram 05, API contract
What stops data leaving?	VPC Service Controls around the backend project and data layer, plus authorised views.	Diagram 02, matrix 2.6
What does the model see?	The user's typed text plus catalogue text. Nothing from the data layer travels with the prompt.	HLD 8
Who promotes a pilot to production?	Published weights applied monthly in SQL over attested metrics and votes. Not model-generated.	HLD 8, DDL
What is new versus already approved?	The web tier, backend, data model and perimeter are new. Everything else is inherited AIB.	Matrix, diagram 02
What are the known gaps?	Four, declared: on-call rota, cross-region DR, the pilot credential in git history, gateway logging policy.	Matrix 7

Before you submit

Four items block the assessment

Region confirmed against the AIB standard; the gateway interface and its prompt-logging policy documented for this use case; lawful basis and the audit-table erasure exemption agreed with Privacy; and the EU AI Act classification agreed with Legal. All nine open items are listed with owners in section 10 of the HLD.

One thing to reconcile with the build

The pack documents all nine backend domain services as in scope. If notification, similarity or AI-assisted intake are still roadmap rather than running in dev, add a current-versus-target marker before submission. Otherwise the Board approves one thing and the first audit finds another.

Outstanding from the pilot

The credential used by the pilot was committed to a public repository and remains in its git history. It is no longer used by anything, but it should be formally rotated and the exposure recorded rather than left to be found by an assessor.

Provenance

The diagrams are produced by a generator built on a small SVG kit that follows Google Cloud diagramming conventions, using the official Google Cloud product icon set. If Vodafone holds a licensed icon pack,

swapping it is a path change in the generator: the layout code is separate from the assets. Ask the AI Domain team for the generator when the architecture moves.